Team RVM (`rvm_team_app`)
Backend Gap & Task Report

What the backend has today, what is missing, and what must be created or updated to meet the **Team RVM App Brief**.

Prepared for: KP (Backend)
Prepared by: Deep code audit of the local repository (no pull / no push)
Date: 16 Oct 2026

READ FIRST — the audited checkout does not match the brief.
The brief (15 Oct 2026) references `Scheduler_Backend` commit `c28b9ca`. That commit **does not exist in this clone** (`git cat-file c28b9ca` → "Not a valid object name"). The newest commit anywhere in the clone is `d2595e4` / a stash dated **24–26 Sep 2026**. A search of every file on every branch, tag and the stash for the attendance/ESS markers (`my-attendance`, `rvm_att_dev`, `OUTSIDE_GEOFENCE`, `staff-attendance`, `attendance-admin`, `server_now`, `holiday`) returns **zero hits**. Therefore every feature the brief calls "Live on web" for attendance is **absent from this checkout**. Items marked **VERIFY** below may already exist in a newer backend that is not in this clone.

Contents

1. Audit basis & method
2. Executive summary
3. Prerequisites / blockers
4. Task backlog A–K
   A. Identity, auth & session
   B. Attendance (employee punch)
   C. Requests, leave & approvals
   D. Inbox, notifications & push
   E. Me — profile, team, documents
   F. Wall
   G. Helpdesk
   H. Role views
   I. Data model additions
   J. Security fixes before launch
   K. Infra / platform
5. Brief "Decisions" the backend depends on
6. What already exists (reusable)
7. Evidence appendix

1. Audit basis & method

Item	Detail
Requirement source	`Team RVM App Brief.pdf` (37 pages, 15 Oct 2026), at `rvm_mobile/apps/doc/`
Backend audited	`Scheduler_Backend` working copy. HEAD `d2595e4` (24 Sep 2026 12:08 IST), on `main`.
Git refs checked	All local branches, all `remotes/origin/*` (fetch date 26 Sep 2026), the stash, `packed-refs`, `FETCH_HEAD`, reflog.
Also reviewed	`Scheduler_frontend` (Aug 2026, student-portal only), `rvm_mobile` (Flutter monorepo), `supabase/migrations`, production schema backups (`public_schema_backup.sql`, `remote_schema`).

Not done	No `git pull`, no `git push`, no fetch. The report reflects code on disk and in already-fetched refs only.
App state	`rvm_mobile/apps/rvm_team_app` is an empty Flutter counter scaffold (only `lib/main.dart`). No screens built.

Status legend used in this report

AVAILABLE exists and usable today (in this checkout)	**UPDATE** exists but must change
MISSING not present — must be created	**VERIFY** brief says live, but not in this checkout — confirm against latest backend

2. Executive summary

Of everything the app needs, the audited backend provides **sign-in / account security**, the **HR organisation record** (employees, org chart, documents — HR-only), and the **faculty / HOD / interview / priority-task** modules. Everything that makes Team RVM a Keka-style employee app is **not present**.

App module	Backend status	One-line verdict
Sign-in (portal)	**AVAILABLE**	Login, 2FA, forgot-password, change password, /api/me all exist.
Sign-in (attendance-only)	**MISSING**	HRMS password-login / OTP / forced-change endpoints absent.
App session / refresh	**MISSING**	64-hour JWT only, no rotating refresh token.
Employee identity layer	**MISSING**	No `employeeAuth` bridging portal + attendance sessions to `hr_employees.id`.
Attendance (punch)	**VERIFY**	Brief says live on web; no punch/geofence/device/calendar code exists in this checkout.
Home (off/holidays/birthdays)	**MISSING**	No holidays, no DOB/blood/emergency data, no “off this week”.
Requests & leave	**MISSING**	No employee request/leave tables or endpoints.
Inbox / approvals	**UPDATE**	Priority tasks exist but are admin-only; approval inbox missing.
Notifications / push	**MISSING**	No FCM, no device tokens, no push worker.
Wall / feed	**MISSING**	No post/praise/poll/announcement-feed backend at all.
Helpdesk	**MISSING**	Only student tickets and the Admin-Manager infra register exist (different audiences).
Me — profile / team	**UPDATE**	HR org data exists but is HR-only (`HR_ROLES = {hr, ceo, super_admin}`); no self-service surface.

Me — documents	UPDATE	`hr_documents` exists; HR uploads only, no verification, returns storage path.
Role views (faculty/ HOD)	UPDATE	Endpoints exist; server-side marking checks and roster trim missing.
Role views (HoO/CEO/ HR board)	MISSING	No staff-attendance board, override, phone-reset endpoints.
Security hardening	MISSING	Several “fix before launch” items are still open in code (Section 4-J).

> **Bottom line for KP:** if the latest backend already contains the attendance/ESS work from the brief, most of Section 4 becomes verification only. If it does not, the entire `/api/ess` surface plus an employee attendance module must be created. **Confirm which backend is current before estimating.**

3. Prerequisites / blockers

The brief lists four things that must be true before launch. Their backend status:

Prerequisite	Status	Notes
One identity for every employee	MISSING	No `employeeAuth` middleware. Portal sessions resolve to `users`; the 41 attendance-only sessions (which are also absent) would resolve nowhere. New self-service endpoints must resolve the caller to `hr_employees.id`.
Roles are right (re-role HOD/HoO)	UPDATE	Operational, not code. `roles.js` already has `hod`, `hoo`, `hod_placement`. No account carries `hod` today (comment in `routes/interviews.js` confirms this).
Portal logins linked to HR records	UPDATE	`hr_employees.user_id` link exists (`20260910000000_hr_employee_user_link.sql`), but HR must finish linking by hand.
One person per login (no shared desks)	MISSING	No server rule or account flag prevents a shared login (e.g. `fbd.admin`) from registering a PIN/phone.

> **Missing role in the backend:** the brief repeatedly names **HR Executive**. `config/roles.js` defines 11 roles (`ceo, super_admin, hoo, hod, hod_placement, admin_manager, admin, accounts_admin, hr, faculty, student`) — **there is no `hr_executive`**. Decision needed: add the role or treat HR Executive as `hr`.

4. Task backlog

Each row: **ID — task**. “Action” is what KP must do: CREATE, UPDATE, or VERIFY. Phase follows the brief (1/2/3/Later).

A. Identity, auth & session

ID	Task	Status	Action	What the app calls / needs
A1	**Employee identity middleware** (generalise today’s `punchAuth`). Accept a portal token **or** an attendance session; resolve caller to their `hr_employees.id`.	MISSING	CREATE	Basis for every `/api/ess/*` route.
A2	**Attendance-login sign-in** (HRMS): password login, OTP request/verify, first-time password + forced change.	MISSING	CREATE	`POST /api/hr/my-attendance/password-login`, `/otp/request`, `/otp/verify`, `/password`; `temporary:true`, lockout 5→15 min.
A3	**Refreshable app session**: short access token + rotating refresh token, stored hashed, bound to install id, revoked on password change / HR disable / exit.	MISSING	CREATE	Currently a 64-hour JWT with no refresh (`authSecurityController.js:29`). Model on the connector refresh tokens in `lib/mcp/oauth.js`.
A4	**Capabilities endpoint** returning tabs, sections and approver rights for the caller.	MISSING	CREATE	`GET /api/ess/me/capabilities`. Role is read on every launch.
A5	**Single-field sign-in resolver** (recommended by brief): one identifier → the right account.	MISSING	CREATE (optional)	Until it exists the app shows the two forms side by side.
A6	**Per-employee rate limiting**, not per office IP.	UPDATE	UPDATE	Current limiter is global/IP (`server.js`). A branch shares one office IP; 300 req/min limit.
A7	**Sign out everywhere** + refuse old tokens after a password change (portal).	MISSING	CREATE	Attendance logins already have `sessions_valid_from`; portal does not.
A8	**Request account/data deletion** form → HR.	MISSING	CREATE	Google Play requires one. Me › “Request correction or deletion”.
A9	**Retire** `POST /api/users/reset-password` (username+phone, no code).	UPDATE	UPDATE	Still registered at `routes/user.js:28`, handler `userController.js:953`. App must never call it.
A10	**Block shared desk logins** from holding PIN / biometric / phone.	MISSING	CREATE	Needs an account flag or policy check server-side.

B. Attendance — employee punch (the largest gap)

> The brief describes this as “Live on web” with a full rule engine. **None of it is in this checkout** — no endpoints, no tables, no shift/holiday/device data. If KP’s latest backend has it, this section is verification; otherwise it is the core build.

ID	Task	Status	Action	Endpoint / rule
B1	**Load today / month** with `server_now`, the day’s note and HR remark in own rows.	VERIFY	CREATE	`GET /api/hr/my-attendance?month=`
B2	**Challenge** valid 2 min, single use.	VERIFY	CREATE	`GET /api/hr/my-attendance/challenge`
B3	**Punch** (kind, nonce, lat, lng, accuracy_m, client_at, note ≤200).	VERIFY	CREATE	`POST /api/hr/my-attendance/punch`; errors `CHALLENGE_REUSED/EXPIRED`, `OUTSIDE_GEOFENCE`, `ACCURACY_LOW`, `DEVICE_*`, `DAY_DONE/ALREADY_IN/NOT_IN`, `PASSWORD_CHANGE_REQUIRED`, `BRANCH_NOT_CONFIGURED/NOT_LINKED`.
B4	**Location ping every 2 min** while punched in.	VERIFY	CREATE	`POST /api/hr/my-attendance/ping`
B5	**Employee’s own day remark** (this month + last).	VERIFY	CREATE	`PUT /api/hr/my-attendance/remarks`
B6	**Geofence per branch** (150 m default) + HR field-staff exemption.	MISSING	CREATE	Needs branch radius config + exemption column.
B7	**GPS accuracy rule** ≤ 100 m (Android scale decision: ×1.6 or app-specific limit).	MISSING	CREATE	`rules.max_accuracy_m`.
B8	**One phone per person**: first accepted punch registers it; HR reset; device-id header as cookie alternative; Keystore key eventually replaces cookie.	MISSING	CREATE	Device registry table + reset endpoint.

B9	**Shifts, shift start/end, grace, week-offs, holidays** per branch.	MISSING	CREATE	No shift/holiday table anywhere (searched all migrations + schema).
B10	**Late / half-day engine**: after shift start + grace; every 3rd late = half day; <4 h = half day; early exit no grace; 00:05 absent/holiday/ week-off close; no overtime.	MISSING	CREATE	Rule engine + midnight cron.
B11	**One session per day**; punch-in reopens at midnight IST.	MISSING	CREATE	`DAY_DONE` handling.
B12	**Holiday list** (this month + next 12 within 120 days, per branch).	MISSING	CREATE	Brief says “Live in the API” — no `holiday` code in this checkout.
B13	**Phone User-Agent enforcement** (`NOT_MOBILE` for default OkHttp/ Dart agents).	MISSING	CREATE	Part of the punch module.
B14	**is_mock flag** on punch/ping (+ RVM’s choice refuse vs flag).	MISSING	CREATE	Recommended: refuse.
B15	**Batch ping upload** with capture times (offline queue) + **ping purge job**.	MISSING	CREATE	Pings are never deleted today.
B16	**Leader/HR attendance board & controls**: live board, override a day, excuse a late, reset a phone, flagged punches.	VERIFY	CREATE	`GET /api/hr/staff-attendance` ; `POST /api/hr/attendance-admin/override` , `/excuse-late` , `/devices/:id/revoke` ; `GET /punches` , `/history` . None present here.

B17	**HR daily-sheet lock** against an approved/ overridden day.	MISSING	CREATE	Admin Manager daily sheet integration.

C. Requests, leave & approvals

ID	Task	Status	Action	Endpoint / rule
C1	**Attendance request tables** + history + `work_mode` (office/WFH/on-duty) on the daily record.	MISSING	CREATE	Two new tables + history; no `work_mode` column today.
C2	**Employee leave** (CL one a month, leave without pay).	MISSING	CREATE / EXTEND	`leave_requests` exists but is the Admin-Manager→faculty flow (`leaveController.js`), not self-service CL/LWP.
C3	**Attendance requests incl. WFH, on-duty, fix-a-day, excuse-late, short-leave** (+ monthly quota counters).	MISSING	CREATE	`POST/GET /api/ess/attendance-requests`.
C4	**Leave requests** (dates, type, reason).	MISSING	CREATE	`POST/GET /api/ess/leave-requests`.
C5	**Leave balances** (allowed / used / remaining, pending included).	MISSING	CREATE	`GET /api/ess/leave/balances`.
C6	**Monthly limits config**: WFH 2, on-duty 4, fix-a-day 3, excuse-late 2, short-leave 120 min, CL 1.	MISSING	CREATE	To be confirmed by RVM (Decision — Section 5).
C7	**One DB function per request type** that decides and writes the day in one transaction.	MISSING	CREATE	Model on `hr_attendance_apply_override` (referenced by brief; not in this checkout).
C8	**Withdraw a pending request**; after approval only HR can cancel.	MISSING	CREATE	—
C9	**Lock approved day** against the Admin Manager daily sheet, like an override.	MISSING	CREATE	—
C10	**Approver resolution**: reporting manager on the HR record, HR fallback; HR/CEO/super can decide any (recorded as HR's).	MISSING	CREATE	Manager = `hr_employees.manager_id`.
C11	**Faculty approved leave updates faculty leave dates** used for batch cover.	UPDATE	UPDATE	`leaveController.js` already mirrors to `faculty.leave_*`; must also reach staff attendance so the midnight job does not mark absent.
C12	**Reach-back window** (this month + last) and **monthly payroll cut-off**.	MISSING	CREATE	Date to be set by RVM.

D. Inbox, notifications & push

ID	Task	Status	Action	Endpoint / rule
D1	**Approvals inbox & decide** with counts, comment, archive.	MISSING	CREATE	`GET /api/ess/approvals`; `POST /api/ess/approvals/:type/:id/decide`.
D2	**Priority tasks visibility**: brief says "every role except the CEO". Today they are admin-only.	UPDATE	UPDATE	Read guard is `requireRole(ADMIN)` (`routes/priorityTasks.js:17`); recipients limited to `admin_manager` / `admin` (`reportingPolicy.js:69`). HR and faculty are blocked.
D3	**Priority task remarks** endpoint (`POST /:id/remarks` in brief).	MISSING	CREATE	Not implemented in `priorityTasksController.js`.
D4	**Multi-level approval chains** with auto-skip; escalation.	MISSING	CREATE	Phase 2.
D5	**FCM device registration**.	MISSING	CREATE	`POST /api/ess/devices`.
D6	**Notifications list + unread count**.	MISSING	CREATE	`GET /api/ess/notifications`.
D7	**Push worker** on Firebase + `FIREBASE_*` secrets with a length check.	MISSING	CREATE	No FCM/Firebase code exists anywhere.
D8	**Notification categories** (mentions, replies, praise, announcements, ack reminders, polls) each opt-out-able; nothing pushed at night.	MISSING	CREATE	—

E. Me — profile, team, directory, documents, ID card

> All HR-record endpoints today are restricted to `HR_ROLES = {hr, ceo, super_admin}` (`config/hrPolicy.js`). Self-service endpoints must be added; they cannot reuse the HR routes.

ID	Task	Status	Action	Endpoint / rul
E1	**Self profile** (Summary / Timeline / Personal / Job), never pay or HR remarks.	MISSING	CREATE	`GET /api/ess/`
E2	**My org chain, department, colleague directory** (search by name/code, filter branch/dept).	MISSING	CREATE	`GET /api/ess/directory`.
E3	**Sensitive change requests** (old + new values → HR approval).	MISSING	CREATE	`POST /api/ess`
E4	**Employee documents**: upload (camera/PDF), verification status, letters folder, 5-min signed link, strip storage path, masked Aadhaar.	UPDATE	CREATE/ UPDATE	`GET/POST /api hr_documents` and returns the
E5	**HR review queues** (change requests, document verification) inside the web HRMS.	MISSING	CREATE	—

E6	**Team today** (All / Not in yet / Late / WFH / On leave) and **Off this week** for anyone with reports.	MISSING	CREATE	Depends on att
E7	**Digital ID card** (photo, name, code, designation, branch, blood group, emergency contact).	MISSING	CREATE	Needs the data
E8	**Colleague contact visibility** rule (email/phone).	MISSING	DECISION	RVM's call — se
E9	**Add HR data columns**: `date_of_birth`, `blood_group`, `address`, `emergency_contact`.	MISSING	CREATE	`hr_employees` `date_of_exit` (`202608260000` add before Pers
E10	**Expose employee photo** to self/team views.	UPDATE	UPDATE	Photo storage e (`202608300000` today.
E11	**Keep notice-period people on the chain** with a "Notice period" chip (web currently drops them).	UPDATE	UPDATE	—
E12	**Timeline from HR events** (joining, confirmation, changes, increments dates only).	UPDATE	UPDATE	`hr_activity_e` read.

F. Wall (new — nothing exists)

ID	Task	Status	Action	Endpoint
F1	**Feed**: posts (text, ≤5 photos/PDFs, @mentions, wall choice), edit 15 min, delete.	MISSING	CREATE	`/api/ess/feed`
F2	**Six reactions** + comments (one level of replies) + reaction-on-comment + who-reacted.	MISSING	CREATE	`/api/ess/feed`
F3	**Praise** with RVM badges (8–12, HR-editable), reason ≤280, optional photo + certificate PDF.	MISSING	CREATE	`/api/ess/praise`, `/badges`
F4	**Polls**: ≥2 options, single/multi, anonymous, closing date, options locked after first vote.	MISSING	CREATE	`/api/ess/polls`
F5	**Announcements**: audience by branch/dept/role/people, schedule, closing date, push+email, read & ack counts, pin ≤3.	UPDATE	CREATE/ UPDATE	`/api/ess/announcements`. Existing `announcements` table is student/batch scope only (columns: title, message, scope, batch_id) — no audience/ack.
F6	**Celebrations**: birthdays (day+month only), anniversaries, new joiners ≤15 days, one-tap wish, hide own birthday.	MISSING	CREATE	`/api/ess/celebrations` (needs DOB — E9).
F7	**Moderation**: report post/comment → HR queue; hide/delete with reason; every action logged.	MISSING	CREATE	`/api/hr/ess-admin`
F8	**Wall settings**: who may post what; HR/CEO/super post announcements.	MISSING	CREATE	`/api/hr/ess-admin`

F9	**Compress photos <1 MB** and store on the server.	MISSING	CREATE	Needs nginx upload-limit raise (K1).

G. Helpdesk (new)

ID	Task	Status	Action	Endpoint
G1	**Categories** (HR-editable) with routing target, priority and SLA per category.	MISSING	CREATE	`/api/ess/helpdesk`
G2	**Tickets + thread + lifecycle** (Open / In progress / On hold / Resolved / Closed), reopen ≤7 d, rating 1–5, withdraw.	MISSING	CREATE	`HD-0001…` numbering.
G3	**Response-time targets** in working hours per branch (shifts/week-offs/holidays), "Overdue by 3h", escalation (category head → HoO → CEO).	MISSING	CREATE	Response-time cron.
G4	**Confidential categories** (HR head + named assignees only, hidden from CEO/super lists, reads logged) and **optional anonymity**.	MISSING	CREATE	—
G5	**Agent workspace**: phone + web queue, filters, bulk close, saved replies, reports.	MISSING	CREATE	—
G6	**Mirror lab/facility tickets into `infra_tickets`** so the AM register stays complete.	UPDATE	UPDATE	`infra_tickets` exists.

H. Role views (faculty / HOD / HoO / leaders)

ID	Task	Status	Action	Endpoint / rule
H1	**Server-side checks on marking attendance**: caller owns the batch, date window, lock after first save, refuse student tokens.	UPDATE	UPDATE	`POST /api/attendance` currently only `auth` + `denyWrite` (`attendanceRoutes.js:43`); `denyWrite` is a no-op. **Security fix.**
H2	**Trim the roster reply** so it returns only the columns the screen needs.	UPDATE	UPDATE	`attendanceController.js:186,191` selects `students(*, is_on_hold)` incl. password hashes. **Security fix.**
H3	**Add `hod_placement` to interviewer roles.**	AVAILABLE	VERIFY	Present in this checkout (`roles.js:9` , migration `20260914000001`). Brief lists it as a fix — confirm it is applied in production.
H4	**HoO "my team today"** attendance view.	MISSING	CREATE	HoO has no attendance read today.
H5	**Light KPI endpoints**; `/api/ceo/dashboard` refuses super admins (8 full scans).	MISSING	CREATE	—

H6	**Approval endpoints for the new request types** (HR).	MISSING	CREATE	Depends on Section C.
H7	**Faculty "my day"** endpoint that knows substitutions; indicators card server data (attendance health, today %, active/total students, unmarked sessions).	UPDATE	CREATE/ UPDATE	Underlying reports exist (`/api/attendance/reports/faculty/:id`), but no aggregation "my day".
H8	**Re-role every HOD and HoO before launch.**	UPDATE	OPS	Not code; otherwise role views show an admin's app.

I. Data model additions (summary)

New tables / columns required across the sections above. None of these exist in the audited schema (all migrations + `public_schema_backup.sql` + `remote_schema` checked).

New tables (indicative):

- `attendance` (employee daily) + `attendance_punches`
- `attendance_challenges` (nonce, 2-min)
- `attendance_pings` (+ purge job)
- `employee_devices` (one phone per person)
- `shifts` , `shift_assignments`
- `holidays` (per branch)
- `attendance_requests` + `_history`
- `leave_requests_ess` / balances (or extend `leave_requests`)
- `refresh_tokens`
- `ess_notifications` , `device_tokens`
- `wall_posts` , `wall_comments` , `wall_reactions`
- `praise` , `badges`
- `polls` , `poll_options` , `poll_votes`
- `ess_announcements` + `_acks` , `celebrations`
- `helpdesk_categories` , `helpdesk_tickets` , `_messages` , `_ratings`
- `ess_change_requests`

Column changes:

- `hr_employees` : `date_of_birth` , `blood_group` , `emergency_contact`
- Daily record: `work_mode` (office/WFH/on_duty)
- `hr_documents` : verification status, HR-defined flag
- Branch: geofence radius, field-staff exempt fl
- Account: shared-desk flag; attendance-sessio

DB functions:

- One decision-and-write function per request t
- Midnight close function (B10/B11)

J. Security fixes before launch (verified present in code)

ID	Issue	Status	Evidence
J1	`POST /api/attendance` accepts any signed-in token (student included) for any batch and date — no caller/date/lock check.	OPEN	`routes/attendanceRoutes.js:43` ; `denyWrite` empty (`roles.js:94`)
J2	Marking roster returns full student rows incl. password hashes.	OPEN	`attendanceController.js:186,191`
J3	Batch create/edit/delete have no role check.	OPEN	`routes/batches.js:9-11`

J4	Announcement create/delete have no role check.	OPEN	`routes/announcements.js:13-14`
J5	Unsafe `POST /api/users/reset-password` (username+phone, no code) still registered.	OPEN	`routes/user.js:28`
J6	Add `hod_placement` to interviewer roles; give HOD/HoO the right role.	PART	Role exists here; production confirm (H3/H8)
J7	Raise nginx upload limit (>1 MB) and add a health + minimum-app-version endpoint.	OPEN	No such route in `server.js`
J8	401 semantics: sign out only on “No token provided” / “Please authenticate”; non-JSON 200 (nginx HTML) must be treated as “server restarting”.	SERVER+CLIENT	~40 endpoints reuse 401 for other reasons
J9	Play Integrity verification server-side (accept `MEETS_DEVICE_INTEGRITY`, not STRONG).	OPEN	Part of punch hardening (B3)

K. Infra / platform

ID	Task	Status	Notes
K1	Raise nginx upload limit (default 1 MB) for document/photo uploads.	MISSING	Documents, wall photos, helpdesk attachments.
K2	Health + minimum-app-version endpoint.	MISSING	Never force an update at the moment of punching.
K3	`FIREBASE_*` secrets in the deploy workflow with a length check.	MISSING	“or push dies silently as the SMS keys once did”.
K4	Per-employee rate limiting (see A6).	UPDATE	One office IP shared by a branch; 300 req/min.
K5	Ping purge job (retention policy) + 180-day access-log retention.	MISSING	Pings are never deleted today.
K6	Play Integrity / Keystore keys; device binding id sent in Play Data safety.	MISSING	Compliance + Play listing.

5. Brief “Decisions” the backend depends on

These 16 decisions from the brief directly change backend behaviour. KP should have answers before building.

Decision	Recommended	Backend impact
Punch button colours	Brand colours	Client only
Tabs for admin roles	All five tabs, no Work section	Capabilities endpoint (A4)
Sign-in screen (one field vs two)	One field	A5 resolver endpoint
Location with screen off	Foreground service	B4 ping + Play declaration
Mocked location	Refuse the punch	B14 is_mock enforcement
Offline punching	Not allowed (v1)	B15 offline queue decision
Who approves requests	Reporting manager, HR fallback	C10 approver resolution
Monthly request limits	WFH 2, on-duty 4, fix 3, excuse 2, short 120 min	C6 config values
Posting on the Wall	Everyone posts; announcements by HR/CEO/super	F8 settings
Colleague contact details	Email to all; phone to manager chain + HR	E8 / directory shape
Pay in the app	Nothing for now	Keep pay out of E1
Moving phones browser→app	HR bulk reset, branch by branch	B8 reset tooling
Build stack	Flutter monorepo	Client
Distribution	Google Play org account + closed testing	Play compliance (K6)
Overtime	Take counsel’s view	Attendance rule engine (B10)
First sign-in	One-time code, password fallback	A2 first-time flow

6. What already exists (reusable by the app)

Everything below is present in the audited backend. **HR-only** and **admin-only** means the app cannot call it directly today.

Sign-in & account security (portal logins)

`POST /api/users/login`, `/login/verify`, `/forgot-password`, `/forgot-password/confirm`, `/change-password`; `GET/POST /api/me`, `/api/me/photo`, `/email/*`, `/phone/*`, `/two-factor/*`, `/password`, `/security-events`.

HR organisation record **(HR-only: hr, ceo, super_admin)**

`/api/hr/employees`, `/people`, `/accounts`, `/org-chart`, `/documents`, `/exits`, compensation, remarks, `/lookups`, `/roles`, `/requisitions`, `/candidates`, `/alerts`, `/dashboard`. Tables: `hr_employees` (manager adjacency + cycle guard, `user_id` link), `hr_departments`, `hr_branches`, `hr_documents`, `hr_activity_events`.

Faculty / HOD / interviews (role views)

`GET /api/batches`, `/api/attendance/batch/:id/daily`, `POST /api/attendance`, `PATCH /api/attendance/remarks`, `/api/attendance/reports/faculty/:id`, `/api/free-slots`; `/api/hod/*`; `/api/faculty-comments`; `/api/interviews/mine/upcoming`, `/capabilities`, `/:roundId/outcome|postpone|resume`.

Priority tasks **(admin-level only)**

`GET /api/priority-tasks/inbox`, `GET/POST /`, `PATCH /:id`, `/:id/cancel`, `POST /:id/ack`, `GET /recipients`.

Admin-Manager ops / registers **(different audience)**

`/api/am/*` (daily/weekly, infra-tickets, faculty leave, utilization, KPIs, reporting-flags); `/api/inventory/requests/*`; `/api/assets/*`; `/api/announcements` (student/batch scope); `/api/tickets` (student portal).

7. Evidence appendix

Claim	Evidence
Audited HEAD date	`git show -s --format='%ci %H' HEAD` → `2026-09-24 12:08:01 +0530 d2595e4`
Brief commit absent	`git cat-file -t c28b9ca` → *Not a valid object name*. Latest ref = stash `0fd00d5` (26 Sep 2026).
No attendance/ESS anywhere	Search of all refs + files for `my-attendance`, `rvm_att_dev`, `OUTSIDE_GEOFENCE`, `staff-attendance`, `attendance-admin`, `server_now`, `holiday` → 0 hits.
No ESS mount	`server.js` route mounts contain no `/api/ess`; no `employeeAuth` in `middleware/`.
HR-only org data	`config/hrPolicy.js`: `HR_ROLES = {hr, ceo, super_admin}`; every `/api/hr/*` route uses `canRead`.
No DOB/blood/emergency	`hr_employees` definition, `20260826000001_hrms_tables.sql:82-131`.
Priority tasks admin-only	`routes/priorityTasks.js:17`; `reportingPolicy.js:69`.

Security gaps J1–J5	`attendanceRoutes.js:43`; `attendanceController.js:186,191`; `routes/batches.js:9-11`; `routes/announcements.js:13-14`; `routes/user.js:28`.
No wall/ helpdesk/ notif tables	Full table list from all migrations + schema backups: no `wall*`, `praise*`, `poll*`, `helpdesk*`, `attendance_request*`, `device*`, `notification*`, `fcm*`.
No push code	No `fcm` / `firebase` /push reference in any backend source.

Recommended next step for KP: confirm which `Scheduler_Backend` revision is the current one. If the Oct 2026 attendance/ESS work exists, re-run this checklist against it — most of Section B/C/D becomes “verify”, and the true remaining work is Section E–K. If it does not, the whole `/api/ess` surface plus the employee attendance engine must be built.